

Мережна безпека

Оскільки організації стикаються з постійно зростаючою кількістю кіберзагроз, надзвичайно важливо, щоб вони мали надійні рішення безпеки.

Існує безліч способів, за допомогою яких зловмисники можуть виявити вразливості та використовувати системи у межах домену.



Зловмисники можуть використовувати системи домену за допомогою наступних складових:

- Прямий фізичний доступ до систем і мереж.
- Бездротова мережа, зона покриття якої виходить за межі організації.
- Пристрої технологій Bluetooth або NFC (Near-Field Communication).
- Зловмисні вкладення електронної пошти.
- Елементи ланцюжка поставок організації, які мають низький рівень безпеки.
- Облікові записи організації в соціальних мережах.
- Знімні носії, такі як флеш-накопичувачі.
- Хмарні застосунки.

Типи кіберзагроз



Програмні атаки (Software attacks)

- Успішна відмова в обслуговуванні (DoS attack).
- Комп'ютерний вірус.



Програмні помилки (Software errors)

- Помилка програмного забезпечення.
- Міжсайтовий скрипт або надання нелегального доступу до ресурсів файлового сервера.



Саботаж (Sabotage)

- Авторизований легальний користувач виконує успішне проникнення та компрометацію основної бази даних організації.
- Спотворення сторінок веб-сайту організації.



Людська помилка (Human error)

- Ненавмисні помилки при введенні даних.
- Некоректні налаштування міжмережного екрана.



Викрадення (Theft)



Відмова обладнання (Hardware failures)



Збої у наданні послуг (Utility interruption)



Стихійні лиха (Natural disasters)

Внутрішні та зовнішні загрози (Threats)

Загрози можуть виникати як всередині організації, так і за її межами.

Внутрішні загрози походять від дійсних чи колишніх співробітників та контрактних партнерів, які випадково чи навмисно некоректно опрацьовують конфіденційні дані або створюють загрози роботі мережної інфраструктури.

Зовнішні загрози походять і від зловмисників-аматорів, і від досвідчених зловмисників. І ті, і інші можуть використовувати вразливості мережних пристроїв або техніки соціальної інженерії для отримання нелегального доступу до внутрішніх ресурсів організації.



Загрози та вразливості користувачів

Відсутність обізнаності з питань кібербезпеки

Користувачі повинні мати знання та розуміння щодо конфіденційних даних, політик та процедур безпеки, технологій та контрзаходів, які впроваджені для захисту інформації та інформаційних систем організації

Недотримання політики безпеки

Усі користувачі повинні мати знання та розуміння політики безпеки організації, а також наслідків її недотримання

Викрадення даних

Викрадені користувачами дані можуть становити значну фінансову загрозу для організацій, як з точки зору заподіяння шкоди репутації, так і/або юридичної відповідальності, пов'язаної з розкриттям інформації

Несанкціоновані завантаження та носії інформації

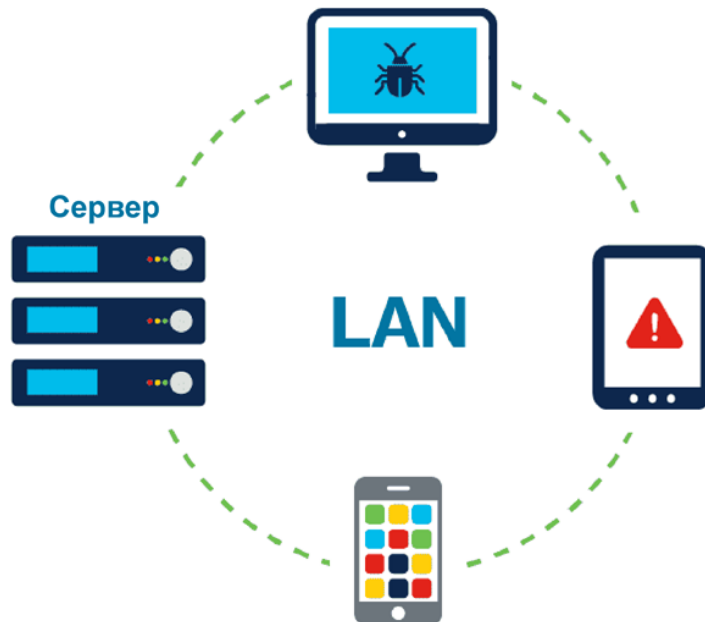
Багато інфікувань та атак на мережі і пристрої можуть бути відстежені від користувачів, які завантажили несанкціоновані електронні листи, фотографії, музику, ігри, програми та відео на свої комп'ютери, мережі чи пристрої зберігання даних, або користувачів, які використовували несанкціоновані носії інформації, зокрема, зовнішні жорсткі диски та USB-накопичувачі

Неавторизовані віртуальні захищені мережі (VPN, Virtual Private Networks)

VPN можуть приховувати викрадення важливої інформації, оскільки шифрування, яке зазвичай використовується для забезпечення конфіденційності

Загрози локальній мережі

Локальна мережа (LAN, Local Area Network) — це сукупність пристроїв, які зазвичай знаходяться на одній території, з'єднаних між собою дротовими або бездротовими лініями зв'язку (кабелями або радіоканалами).



Приклади загроз для локальної мережі:

- Несанкціонований доступ до комутаційних шаф, центрів обробки даних, приміщень з комп'ютерами.
- Несанкціонований доступ до систем, програм і даних.
- Вразливості та оновлення мережних операційних систем та програмного забезпечення.
- Несанкціонований доступ користувачів-зловмисників до безпроводних мереж.
- Несанкціоноване використання даних під час передавання.
- Наявність різного обладнання або операційних систем на серверах локальної мережі значно ускладнює процедури керування ними та процедури усунення їх несправностей.
- Несанкціоноване зондування мережі та сканування портів мережних вузлів.
- Некоректні налаштування міжмережних екранів.

Загрози приватній та публічній хмарі



Домен приватної хмари містить будь-які приватні сервери, ресурси та ІТ-інфраструктуру, доступні через Інтернет лише для співробітників певної організації.

Цей домен все ще має значні безпекові загрози, зокрема:

Неавторизоване мережеве зондування та сканування портів

Неавторизований доступ до ресурсів

Можливостей віддаленого доступу

На відміну від домену приватної хмари, який містить обчислювальні ресурси лише однієї організації, домен публічної (загальнодоступної) хмари (**Public cloud domain**) з наявною сукупністю обчислювальних послуг, розміщений у хмарі або на базі Інтернет-провайдера чи провайдера послуг, є загальнодоступним та спільним для багатьох організацій.



SaaS (Програмне забезпечення як послуга)

Ця модель базується на підписці і надає можливість організації централізовано розміщувати програмне забезпечення та надавати користувачам доступ до нього через веб-браузери, застосунки чи в інший спосіб.



PaaS (Платформа як послуга)

Ця модель базується на підписці і надає можливість організації використовувати певну платформу для розробки, виконання та керування застосунками на базі апаратного забезпечення та інструментів провайдера сервісу. Доступ до цієї платформи здійснюється через публічну хмару.



IaaS (Інфраструктура як послуга)

Ця модель базується на підписці і надає можливість організації через мережу Інтернет використовувати різноманітні віртуальні обчислювальні ресурси, а саме апаратне забезпечення, програмне забезпечення, сервери, системи збереження даних та інші інфраструктурні компоненти.

Тактики соціальної інженерії



Авторитетне джерело

Зловмисники користуються тим фактом, що ймовіріше люди виконають інструкції тих осіб, яких вони вважають авторитетними.



Залякування

Кіберзлочинці досить часто тиснуть чи залякують жертву з метою примушення до виконання дій, які ставлять під загрозу безпеку.



Дефіцит

Добре відома маркетингова тактика, атаки дефіциту спрацьовують, оскільки зловмисники знають, як люди схильні діяти у ситуаціях, коли думають, що доступна обмежена кількість чогось.



Терміновість

Люди також схильні діяти аналогічно, коли думають, що для прийняття рішення є обмежений час.



Консенсус

Атаки консенсусу, відомі також як «соціальний доказ» теж спрацьовують, бо люди схильні діяти так само, як і інші люди навколо них.



Знайомство

Люди, ймовіріше, роблять те, про що їх просить саме знайома приязна особа.

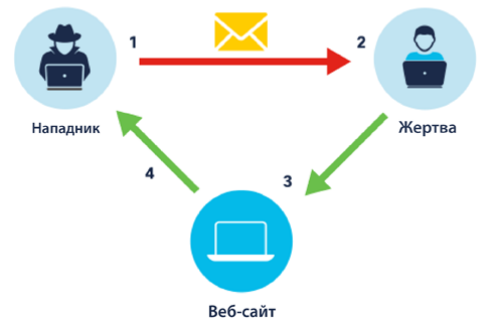


Довіра

Кіберзлочинець, замаскований під експерта з безпеки, телефонує для надання поради жертві, яка нічого не підозрює. Допомагаючи жертві, злочинець нібито виявляє «серйозну помилку», яка потребує негайної уваги.

Міжсайтовий скриптинг

Міжсайтовий скриптинг (XSS, Cross-Site Scripting) - це поширена вразливість:



1. Кіберзлочинці використовують XSS-уразливість, включаючи у веб-сторінки сценарії, що містять шкідливий код.
2. Жертва відкриває веб-сторінку і зловмисні скрипти приховано передаються до її браузера.
3. Шкідливий скрипт може отримати доступ до будь-яких файлів cookie, сесійних токенів або іншої конфіденційної інформації про користувача, і ці дані надсилаються кіберзлочинцеві.
4. Отримавши цю інформацію, кіберзлочинець може видавати себе за користувача.

Ін'єкція коду

Атака XML-ін'єкція (XML Injection Attack)

Атака XML-ін'єкція може пошкодити дані бази даних XML та загрожувати безпеці веб-сайту.

Вона працює шляхом втручання в обробку даних XML або запиту, введеного користувачем.

Атака SQL-ін'єкція (SQL Injection Attack)

Кіберзлочинці можуть проводити атаки SQL-ін'єкцій на веб-сайти або будь-які бази даних SQL, додавши зловмисний оператор SQL у поле введення.

Ця атака використовує особливості вразливості, у якій програма неправильно фільтрує введені користувачем дані, як символи оператора SQL.

Атака DLL-ін'єкція (DLL Injection Attack)

Файл бібліотеки динамічних посилань (DLL, Dynamic Link Library) – це файл-бібліотека, який містить код та дані, необхідні для виконання певних дій в ОС Windows. Програми використовують файли цього типу у випадках, коли певні функції не є вбудованими у програми.

Атака LDAP-ін'єкція (LDAP Injection Attack)

Атака LDAP-ін'єкція використовує вразливості перевірки введення даних, за рахунок впровадження та виконання запитів до LDAP-серверів

Загроза, вразливість та ризик

При обговоренні питань мережної безпеки важливо знати такі терміни:

Загроза

Потенційна небезпека для активів, таких як дані або, власне, мережа.

Вразливість

Це слабе місце в системі або в її проєкті, яке може бути використане зловмисником.

Поверхня атаки (Attack Surface)

Це загальна сукупність вразливостей певної системи, яка доступна зловмисникові. Поверхня атаки описує різні точки, через які хакер може проникнути до системи або отримати дані з системи. Наприклад, вашій операційній системі та веб-браузеру можуть знадобитися виправлення безпеки. Вони обоє вразливі до атак та відкриті у мережі або в Інтернеті. Разом вони створюють поверхню атаки, яку може виконати зловмисник.

Експлойт (Exploit)

Механізм, через який вразливість використовується для компрометації активу. Експлойти можуть бути віддаленими або локальними. Віддалений експлойт (Remote Exploit) працює через мережу і заздалегідь не потребує доступу до цільової системи. Зловмисникові для використання вразливості не потрібен обліковий запис у системі-жертві. У випадку локального експлойта (Local Exploit), зловмисник має деякі права користувачького або адміністративного доступу до системи-жертви. Локальний експлойт не обов'язково означає, що зловмисник має фізичний доступ до кінцевої системи.

Ризик (Risk)

Це ймовірність того, що конкретна загроза використає певну вразливість активу і призведе до небажаних наслідків.

Інші поширені терміни, пов'язані з мережною безпекою:

- **Захід протидії, контрзахід** – захід, який впроваджуються для захисту активів з метою зменшення загрози або зниження ризику.
- **Вплив** – потенційні збитки організації, спричинені певною загрозою.

Примітка: для локального експлойта необхідний доступ всередині мережі, наприклад, обліковий запис користувача мережі. Віддалений експлойт для використання вразливості не вимагає облікового запису користувача мережі.

Ризик-менеджмент

Ризик-менеджмент – це процес знаходження компромісу між експлуатаційними витратами на забезпечення запобіжних заходів та виграшем в результаті захисту активів. Існує чотири основні способи управління ризиками:

Прийняття ризику (Risk Acceptance)

Випадок, при якому вартість варіантів управління ризиком перевищує вартість самого ризику. Ризик прийнято і жодних дій не вживається.

Уникнення ризику (Risk Avoidance)

Випадок, який передбачає уникнення будь-якого впливу ризику шляхом усунення діяльності або пристрою, від якого походить ризик. Якщо для уникнення ризику усунути певну діяльність, то будь-які доступні від такої діяльності вигоди будуть втрачені.

Зниження ризику (Risk Reduction)

Випадок, який передбачає зменшення схильності до ризику або зменшення впливу ризику за рахунок запровадження заходів для зниження ризику. Цей випадок є найпоширенішою стратегією зниження ризиків. Ця стратегія вимагає ретельної оцінки вартості збитків, стратегії зменшення наслідків, а також вигод, отриманих від операції або діяльності, що піддається ризику.

Передача ризику (Risk Transfer)

Випадок у якому частина або увесь ризик передається зацікавленій третій стороні, наприклад, страховій компанії.

Вектор атаки

Вектор атаки — це спосіб, у який зловмисник може отримати доступ до сервера, вузла або мережі. Вектори атаки можуть походити як зсередини, так і ззовні корпоративної мережі. Наприклад, зловмисники через Інтернет можуть скеровувати свої зусилля на певну мережу з метою порушення її роботи або виконувати атаку відмови в обслуговуванні (DoS).

IPv4



Версія

- Містить 4-бітове двійкове значення, встановлене 0100, яке ідентифікує його як пакет IPv4.

Довжина заголовка (Internet Header length, IHL)

- Це 4-бітове поле, що містить довжину заголовка IP.
- Мінімальна довжина заголовка IP становить 20 байтів.

Диференційовані сервіси (Differentiated Services or DiffServ, DS)

- Раніше це поле називалось Тип служби (Type of Service, ToS). DS – це 8-бітове поле, яке використовується для визначення пріоритету кожного пакета.
- Шість найбільш значущих бітів поля DiffServ – це Точка коду диференційованих сервісів (Differentiated Services Code Point, DSCP).
- Останні два біти – це біти Явного сповіщення про перевантаження (Explicit Congestion Notification, ECN).

Загальна довжина

- Визначає довжину IP-пакета, який містить IP-заголовок та дані користувача.
- Розмір поля Загальної довжини 2 байти, тому максимальний розмір IP-пакета може складати 65 535 байтів, однак зазвичай розміри пакетів набагато менші.

Ідентифікація, Прапорець та Зсув фрагмента

- Тоді пакет буде поділено або фрагментовано на менші пакети і знову зібрано згодом.
- Ці поля використовуються для фрагментації та повторного збирання пакетів.

Час життя (Time-to-Live , TTL)

- Містить 8-бітове двійкове значення, яке використовується для обмеження часу життя пакета.
- Відправник пакетів встановлює початкове значення TTL, яке зменшується на одиницю щоразу при обробці пакета маршрутизатором.
- Якщо поле TTL зменшиться до нуля, маршрутизатор відкидає пакет і відправляє ICMP-повідомлення про перевищення часу (Time Exceeded) на IP-адресу джерела.

Протокол

- Це поле використовується для ідентифікації протоколу наступного рівня.
- Це 8-бітове двійкове значення вказує тип корисного навантаження даних, які містить пакет, що дозволяє мережному рівню передавати дані до відповідного протоколу верхнього рівня.
- Зазвичай використовуються такі значення: ICMP (1), TCP (6) та UDP (17).

Контрольна сума заголовка

- Значення, яке обчислюється на основі вмісту заголовка IP.
- Використовується для визначення, чи були внесені помилки під час передавання.

IPv4-адреса джерела

- Містить 32-бітове двійкове значення, яке представляє IPv4-адресу джерела пакета.
- IPv4-адреса джерела завжди є індивідуальною.

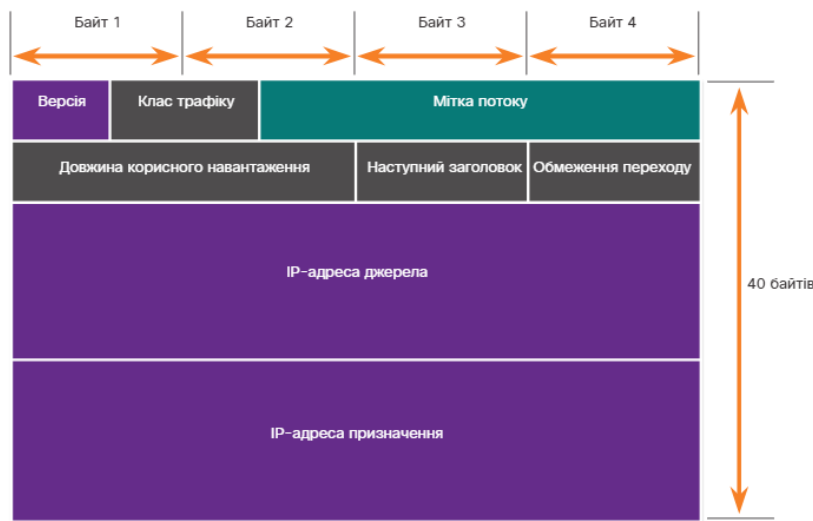
IPv4-адреса призначення

- Містить 32-бітове двійкове значення, яке представляє IPv4-адресу призначення пакета.

Параметри та Заповнення

- Це поле змінної довжини, яка може коливатись від 0 до значення, кратного 32 бітам.
- Якщо значення параметрів не є кратними 32 бітам, то для забезпечення кратності вони доповнюються нулями.

IPv6



Версія

- Це поле містить 4-бітове двійкове значення, встановлене 0110, яке ідентифікує його як пакет IPv6.

Клас трафіку

- Це 8-бітове поле еквівалентне полю IPv4 Диференційовані сервіси (DS).

Мітка потоку

- Це 20-бітове поле передбачає, що всі пакети з однаковими мітками потоку будуть оброблятися маршрутизаторами однаково.

Довжина корисного навантаження

- Це 16-бітове поле показує довжину блока даних або корисного навантаження пакета IPv6.

Наступний заголовок

- Це 8-бітове поле еквівалентне полю Протокол в заголовку IPv4.
- Воно вказує на тип даних корисного навантаження, яке переносить пакет, дозволяючи мережному рівню скеровувати дані до відповідного протоколу верхнього рівня.

Обмеження переходу

- Це 8-бітове поле, яке замінило поле Час життя (TTL) заголовку IPv4.
- Кожний маршрутизатор, який пересилає пакет, зменшує це значення на 1.
- Як тільки лічильник досягне значення 0, пакет буде відкинуто, а вузлові-відправнику надіслано повідомлення ICMPv6 Time Exceeded, яке вказує, що пакет не досяг свого адресата, оскільки перевищено межу кількості переходів.

IPv6-адреса джерела

- Це 128-бітове поле ідентифікує IPv6-адресу вузла-відправника.

IPv6-адреса призначення

- Це 128-бітове поле ідентифікує IPv6-адресу вузла-одержувача.

Вразливості IP

Атаки на основі ICMP

Нападник використовує пакети ехо-запитів (ping) протоколу ICMP для виявлення підмереж і вузлів у захищеній мережі з метою створення лавини DoS-атак та зміни таблиць маршрутизації вузла.

Атаки типу Відмова в обслуговуванні (DoS-атаки)

Хакери намагаються унеможливити доступ до інформації або сервісів законним користувачам.

Розподілені атаки типу Відмова в обслуговуванні (DDoS-атаки)

Аналогічні DoS-атакам, але є одночасною, скоординованою атакою з декількох комп'ютерів-джерел.

Атаки з підміною адрес

Зловмисники підробляють IP-адресу джерела, намагаючись виконати відкриту підміну або підміну наосліп.

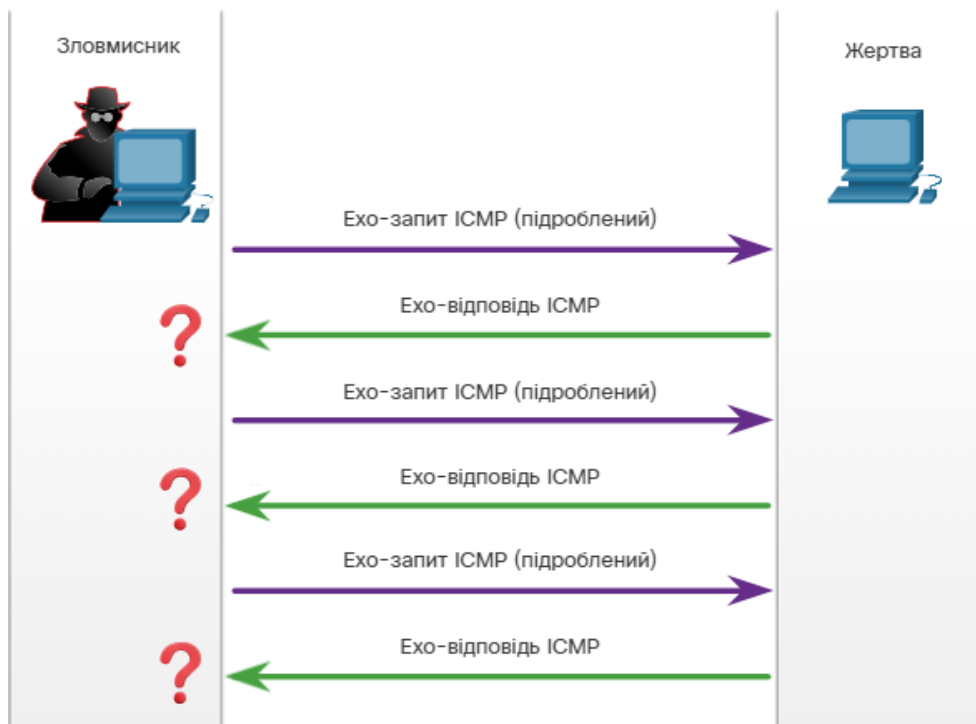
Атака типу Людина посередині (MiTM)

Зловмисники розташовуються між джерелом і одержувачем трафіку для прозорого моніторингу, перехоплення і контролю з'єднання. Вони можуть просто прослуховувати, перевіряючи захоплені пакети, або змінювати пакети та пересилати їх за початковою адресою призначення.

Захоплення сеансу

Нападник одержує доступ до фізичної мережі, після чого за допомогою атаки MiTM захоплює сеанс зв'язку.

Атака ICMP



TCP



Шість контрольних бітів TCP-сегмента:

- **URG** - Urgent - поле показчику терміновості
- **ACK** - Acknowledgment - поле підтвердження
- **PSH** - Push - функція просування
- **RST** - Reset - перемикання з'єднання
- **SYN** - Synchronize - синхронізація порядкових номерів
- **FIN** - Finish - немає більше даних від відправника

TCP забезпечує такі функції:

- **Надійна доставка** – TCP підтримує механізм підтвердження, який гарантує доставку, замість того, щоб при виявленні та виправленні помилок покладатися на протоколи верхніх рівнів. За відсутності своєчасного підтвердження, відправник повторно передає дані. Проте, необхідність у підтвердженні доставки даних може призвести до значних затримок. До протоколів прикладного рівня, що використовують функцію надійності TCP, належать HTTP, SSL/TLS, FTP, передавання зон DNS та інші.
- **Керування потоком даних** – Для вирішення проблем із доставкою у TCP реалізовано контроль за потоком даних. Замість того, щоб підтверджувати кожен сегмент, можна за допомогою одного сегмента підтвердження повідомити про отримання відразу кількох сегментів.
- **Встановлення з'єднання** – Налаштування з'єднання зі збереженням стану між двома сторонами у TCP забезпечується за допомогою тристороннього рукостискання. Як показано на рисунку, перш ніж передавати дані через TCP, під час процесу тристороннього рукостискання відбувається відкриття TCP-з'єднання. Якщо обидві сторони погоджуються на з'єднання, вони можуть обмінюватися даними за допомогою TCP.

UDP



Послугами UDP зазвичай користуються протоколи DNS, DHCP, TFTP, NFS та SNMP, а також застосунки реального часу, такі як потокове відео або VoIP. UDP – це протокол транспортного рівня без встановлення з'єднання. У порівнянні з TCP, він створює значно менше накладних витрат, оскільки не орієнтований на з'єднання і не підтримує складні механізми ретрансляції, упорядкування та керування потоком, які забезпечують надійність. Як показано на рисунку, UDP-сегмент за структурою значно простіший за TCP.

Примітка: UDP фактично ділить дані на дейтаграми. Однак зазвичай використовується загальний термін «сегмент».

Хоча UDP зазвичай називають ненадійним у порівнянні з TCP, це не означає, що він є протоколом нижчої якості, або, що програми, які його використовують, нестабільно працюють. Це означає, що функції забезпечення надійності не забезпечуються протоколом транспортного рівня і, в разі потреби, повинні бути реалізовані на інших рівнях.

Низькі накладні витрати UDP сприятливі для протоколів, що працюють у режимі простих транзакцій запит-відповідь. Наприклад, використання TCP для DHCP призвело б до збільшення обсягу мережного трафіку. Якщо відповідь не отримано, пристрій повторно надсилає запит.

UDP не забезпечує захисту за допомогою шифрування. Функції шифрування можна додати до протоколу UDP, проте за замовчуванням вони недоступні. Відсутність шифрування дозволяє будь-кому переглядати трафік, змінювати його та надсилати за призначенням.

Захист мережі

Щоб захистити мережу від атак, потрібні постійна пильність і безперервне навчання. Нижче наведено найкращі методи захисту мережі:

- Розробити письмову політику безпеки для компанії.
- Поінформувати співробітників про ризики соціальної інженерії та розробити стратегії для підтвердження особи по телефону, електронною поштою або особисто.
- Контролювати фізичний доступ до систем.
- Використовувати надійні паролі та часто змінювати їх.
- Шифрувати та захищати конфіденційні дані паролем.
- Впроваджувати обладнання та програмне забезпечення безпеки, наприклад брандмауери, системи запобігання вторгненням (IPS), пристрої віртуальної приватної мережі (VPN), антивірусне програмне забезпечення та фільтрацію вмісту.
- Регулярно створювати резервні копії та перевіряти файли резервних копій.
- Вимкнути непотрібні служби та порти.
- Підтримувати актуальність оновлень, встановлюючи їх щотижня або щодня, якщо це можливо, щоб запобігти переповненню буфера та атакам ескалації привілеїв.
- Виконувати аудит безпеки для перевірки мережі.

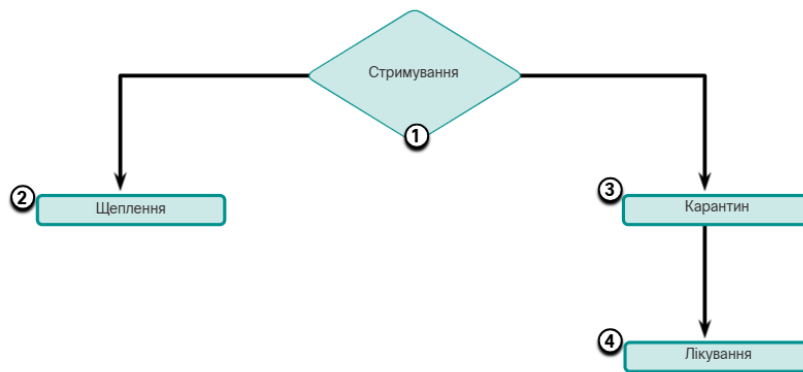
Пом'якшення дії шкідливого програмного забезпечення

Одним зі способів пом'якшення вірусних і троянських атак є антивірусне програмне забезпечення. Антивірусне програмне забезпечення допомагає запобігти зараженню вузлів і поширенню шкідливого коду. Для очищення заражених комп'ютерів потрібно набагато більше часу, ніж для підтримки актуального антивірусного програмного забезпечення та визначень антивірусів на тих же машинах.

На сьогодні антивірусне програмне забезпечення є найпоширенішим продуктом безпеки на ринку. Кілька компаній, що створюють антивірусне програмне забезпечення, такі як Symantec, McAfee і Trend Micro, займаються виявленням і знищенням вірусів більше десяти років. Багато корпорацій та навчальних закладів купують для своїх користувачів корпоративне ліцензування. Користувачі можуть увійти на веб-сайт за допомогою свого облікового запису та завантажити антивірусне програмне забезпечення на свої настільні комп'ютери, ноутбуки чи сервери.

Антивірусні продукти мають параметри автоматизації оновлення, щоб нові визначення вірусів та свіжі оновлення програмного забезпечення можна було завантажувати автоматично або за запитом. Ця практика є найважливішою вимогою для захисту мережі від вірусів і повинна бути формалізована в політиці безпеки мережі.

Пом'якшення дії хробаків



Стимування

Фаза стимування або локалізації розповсюдження передбачає обмеження поширення зараження хробаком до ділянки мережі, яка вже уражена. Це вимагає розділення та сегментації мережі, щоб уповільнити чи зупинити хробака і не допустити, щоб вже заражені вузли націлювались на інші системи і заражали їх. Для стимування потрібно використовувати як вихідні, так і вхідні списки керування доступом на маршрутизаторах і брандмауерах в контрольних точках мережі.

Щеплення

Фаза щеплення проходить паралельно або після фази локалізації. Під час фази щеплення всі незаражені системи виправляються відповідним патчем постачальника. Процес щеплення додатково позбавляє хробака будь-яких доступних цілей.

Карантин

Фаза карантину включає відстеження та ідентифікацію заражених машин у закритих зонах та їх від'єднання, блокування або видалення. Це забезпечує належну ізоляцію цих систем для етапу лікування.

Лікування

Фаза лікування передбачає активну дезінфекцію заражених систем. Це може включати припинення процесу хробака, видалення змінених файлів або системних налаштувань, які запровадив хробак, і виправлення вразливості, яку хробак використовував для експлуатації системи. Крім того, у більш серйозних випадках може знадобитися перевстановлення системи, щоб гарантувати видалення хробака та його побічних продуктів.

Порівняння бездротових та дротових локальних мереж

Бездротові локальні мережі (WLAN) використовують радіочастоти (RF) замість кабелів на фізичному рівні та підрівні керування доступом до середовища (MAC) Канального рівня. WLAN мають спільне з локальними мережами Ethernet походження. Інститут інженерів з електротехніки та електроніки (IEEE) прийняв портфоліо 802 LAN / MAN стандартів архітектури комп'ютерної мережі. Двома основними стандартами робочої групи 802 є стандарт 802.3 Ethernet, що визначає Ethernet для дротових локальних мереж, та стандарт 802.11, що визначає Ethernet для WLAN. Між ними існують важливі відмінності.

WLAN також відрізняються від дротових локальних мереж:

WLAN під'єднують клієнтів до мережі через бездротову точку доступу (AP) чи бездротовий маршрутизатор, а не комутатор Ethernet.

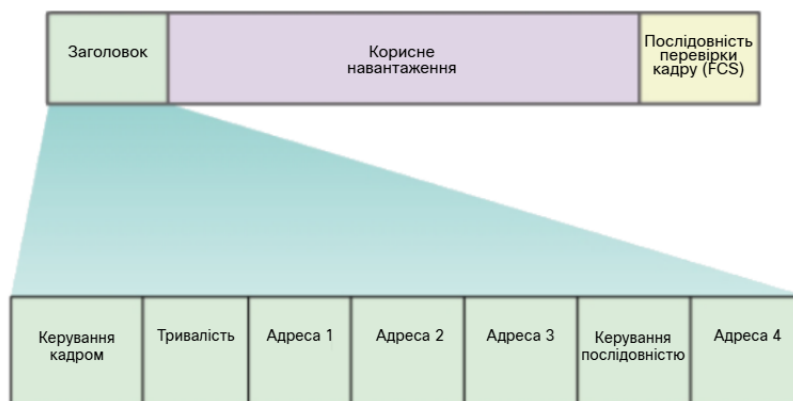
WLAN під'єднують мобільні пристрої, які часто працюють на акумуляторі, на відміну від пристроїв локальної мережі з постійним живленням. Бездротові мережні карти, як правило, знижують термін служби акумулятора мобільного пристрою.

WLAN підтримують вузли, які претендують на доступ до радіочастотної смуги (діапазону частот). 802.11 передбачає механізм запобігання колізій (CSMA/CA) замість виявлення колізій (CSMA/CD) для доступу до середовища, щоб активно уникати колізій у середовищі передавання.

WLAN використовують відмінний від дротових локальних мереж Ethernet формат кадрів. WLAN вимагають додаткової інформації у заголовку кадра Рівня 2.

Бездротові локальні мережі викликають більше проблем із конфіденційністю, оскільки радіочастоти можуть виходити за межі об'єкта.

Структура кадра 802.11



Всі бездротові кадри 802.11 містять такі поля:

- **Керування кадром (Frame Control)** - визначає тип бездротового кадра та містить підполя Версія протоколу, Тип кадра, Тип адреси, Керування живленням та Параметри безпеки.
- **Тривалість (Duration)** - зазвичай використовується для позначення часу, необхідного для отримання наступної передачі кадра.
- **Адреса1 (Address1)** - зазвичай містить MAC-адресу приймаючого бездротового пристрою або точки доступу.
- **Адреса2 (Address2)** - зазвичай містить MAC-адресу передавального бездротового пристрою або точки доступу.
- **Адреса3 (Address3)** - іноді містить MAC-адресу отримувача, наприклад, інтерфейс маршрутизатора (шлюз за замовчуванням), до якого приєднано точку доступу.
- **Керування послідовністю (Sequence Control)** - містить інформацію для керування послідовністю і фрагментованими кадрами.
- **Адреса4 (Address4)** - зазвичай порожнє, тому що використовується лише в режимі ad hoc.
- **Корисне навантаження (Payload)** - містить дані для передавання.
- **Послідовність перевірки кадру (FCS)** - використовується для контролю помилок Рівня 2.

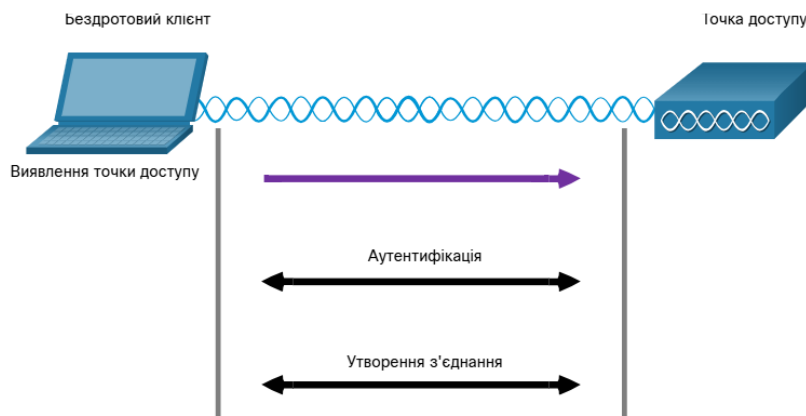
WLAN працюють у напівдуплексному режимі та мають спільне середовище передавання. Напівдуплекс означає, що передавати чи отримувати в будь-який момент може лише один клієнт. Спільне середовище передавання інформації означає, що бездротові клієнти можуть передавати і приймати по одному радіоканалу. Це створює проблему, оскільки бездротовий клієнт не може прослуховувати канал під час надсилання, а це унеможливорює виявлення колізії.

Для вирішення цієї проблеми WLAN використовують технологію множинного доступу з контролем несучої та уникненням колізій (CSMA/CA, Carrier Sense Multiple Access with Collision Avoidance) як метод визначення, як і коли надсилати дані в мережі.

Утворення з'єднання між бездротовим клієнтом і точкою доступу

Для взаємодії у мережі бездротові пристрої спочатку повинні зв'язатися з точкою доступу або бездротовим маршрутизатором. Важливою частиною процесу 802.11 є пошук бездротової локальної мережі з наступним під'єднанням до неї. При цьому, бездротові пристрої виконують такі три кроки, зображені на рисунку:

- Пошук (виявлення) бездротової AP
- Аутентифікація з AP
- Утворення з'єднання (асоціація) з AP



SSID

ідентифікатор SSID з'являється у списку доступних для клієнта бездротових мереж. У великих організаціях, які використовують кілька VLAN для сегментування трафіку, кожній VLAN відповідає свій SSID. Залежно від конфігурації мережі декілька точок доступу можуть спільно використовувати загальний SSID.

Пароль (Password)

необхідний бездротовому клієнту для аутентифікації точкою доступу.

Режим мережі (Network mode)

стосується стандартів WLAN 802.11a/b/g/n/ac/ad. Точки доступу та бездротові маршрутизатори можуть працювати в змішаному режимі, тобто можуть одночасно підтримувати клієнтів, під'єднаних через кілька різних стандартів.

Режим безпеки (Security mode)

стосується параметрів безпеки, таких як WEP, WPA або WPA2. Завжди застосовуйте найвищий доступний рівень безпеки.

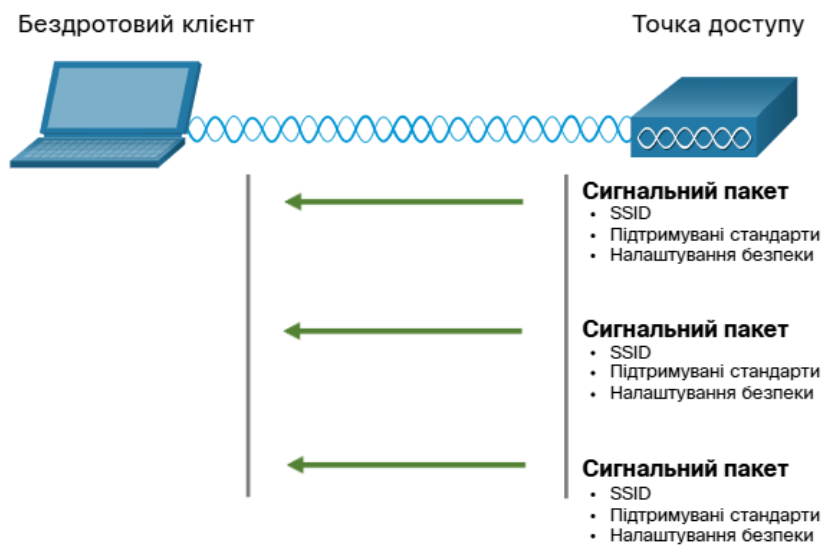
Налаштування каналу (Channel settings)

стосується частотних діапазонів, які використовуються для бездротового передавання даних. Бездротові маршрутизатори і точки доступу можуть сканувати радіочастотні канали та автоматично обирати відповідне налаштування каналу. Також канал можна встановити вручну, в разі втручання іншої точки доступу чи бездротового пристрою.

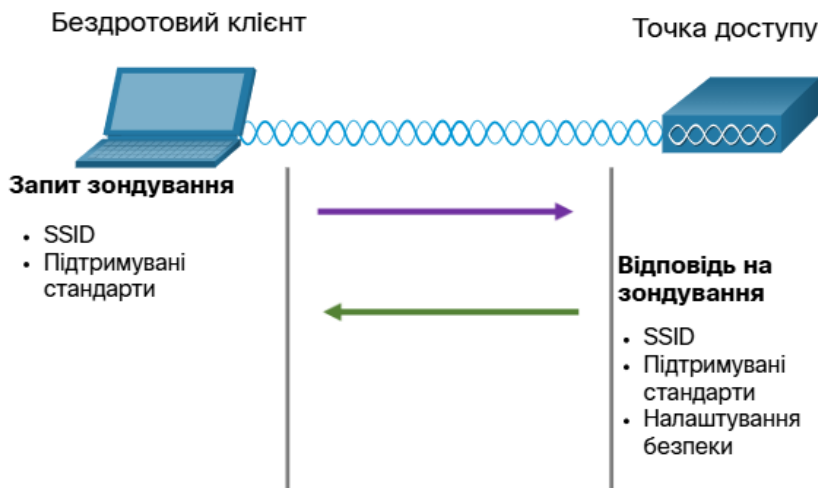
Пасивний та активний режим виявлення

Бездротові пристрої повинні виявляти та під'єднуватись до точки доступу чи бездротового маршрутизатора.

У пасивному режимі AP відкрито повідомляє про свої сервіси, періодично надсилаючи широкомовні сигнальні кадри, що містять ідентифікатор SSID, підтримувані стандарти та налаштування безпеки. Основна мета сигнальних кадрів полягає у наданні бездротовим клієнтам інформації про точки доступу та мережі, доступні в заданій області.



В активному режимі бездротові клієнти повинні знати назву SSID. Бездротовий клієнт ініціює процес, транслуючи кадр запиту зондування на декілька каналів. Запит зондування містить ідентифікатор SSID та підтримувані стандарти. Точки доступу, на яких налаштовано SSID, надсилатимуть відповідь на зондування, яка включає SSID, підтримувані стандарти та параметри безпеки.



Методи автентифікації зі спільним ключем

Метод автентифікації	опис
Wired Equivalent Privacy (WEP)	Оригінальна специфікація 802.11 розроблена для захисту даних за допомогою методу шифрування Rivest Cipher 4 (RC4) зі статичним ключем. Однак ключ ніколи не змінюється під час обміну пакетами. Завдяки цьому його легко зламати. WEP більше не рекомендується і ніколи не повинен використовуватися.
Захищений доступ Wi-Fi (WPA)	Стандарт Wi-Fi Alliance, який використовує WEP, але захищає дані за допомогою набагато потужнішого алгоритму шифрування протоколу цілісності тимчасового ключа (TKIP). TKIP змінює ключ для кожного пакета, що значно ускладнює його злом.
WPA2	WPA2 – поточний промисловий стандарт для захисту бездротових мереж. Для шифрування використовується Advanced Encryption Standard (AES). Наразі AES вважається найнадійнішим протоколом шифрування.
WPA3	Наступне покоління безпеки Wi-Fi. Усі пристрої з підтримкою WPA3 використовують новітні методи безпеки, забороняють застарілі протоколи та вимагають використання захищених кадрів керування (PMF). Однак пристрої з WPA3 поки що недоступні.

Аутентифікування домашнього користувача

Персональний (Personal)

призначений для домашніх або невеликих офісних мереж, для аутентифікації користувачів використовується попередньо визначений спільний ключ (PSK, Pre-Shared Key). Бездротові клієнти автентифікуються за допомогою бездротового маршрутизатора, використовуючи попередньо визначений спільний пароль. Спеціальний сервер для аутентифікації не потрібен.

Корпоративний (Enterprise)

призначений для корпоративних мереж, але потребує сервера аутентифікації за протоколом RADIUS (Remote Authentication in Dial-In User Service) для автентифікації, авторизації та обліку різноманітних сервісів. Попри складність у налаштуваннях, він забезпечує додаткову безпеку. Пристрій повинен засвідчуватися сервером RADIUS, після чого користувачі проходять аутентифікацію за стандартом 802.1X, який для цього використовує Розширюваний протокол аутентифікації (EAP, Extensible Authentication Protocol).

Розширений стандарт шифрування

(AES, Advanced Encryption Standard) - це метод шифрування, який використовується у WPA2. Перевага надається саме цьому методу як набагато надійнішому способу шифрування. Він використовує протокол блочного шифрування з кодом автентичності повідомлення і режимом зчеплення блоків та лічильника (CCMP, Counter Cipher Mode with Block Chaining Message Authentication Code Protocol), який дозволяє вузлам призначення розпізнати, чи були змінені зашифровані та незашифровані біти.

Поширені архітектури безпеки

Приватні та загальнодоступні

- Трафік, що генерується з приватної мережі, дозволяється та перевіряється, коли він переходить у загальнодоступну мережу. Перевірений трафік, що повертається із загальнодоступної мережі та пов'язаний із трафіком, який походить із приватної мережі, дозволяється.
- Як правило, трафік, що надходить із загальнодоступної мережі та переходить у приватну мережу, блокується.

Демілітаризована зона (DMZ)

- Трафік, що надходить із приватної мережі, перевіряється, коли він направляється у загальнодоступну мережу або мережу DMZ. Цей трафік дозволяється з невеликими обмеженнями або без обмежень. Перевірений трафік, який повертається з DMZ чи загальнодоступної мережі у приватну, дозволяється.
- Трафік, який надходить із мережі DMZ та прямує до приватної мережі, зазвичай блокується.
- Трафік, що надходить з мережі DMZ та прямує до публічної мережі, вибірково дозволяється на основі вимог до послуг.
- Трафік, що надходить з публічної мережі та прямує до DMZ, вибірково дозволяється та перевіряється. Зазвичай цей тип трафіку – це електронна пошта, DNS-, HTTP- або HTTPS-трафік. Динамічно дозволено зворотний трафік із DMZ у загальнодоступну мережу.
- Трафік, що надходить із публічної мережі та направляється в приватну мережу, блокується.

Брандмауери на основі зонної політики

Брандмауери на основі зонної політики (ZPF, Zone-based Policy Firewall) використовують концепцію зон для забезпечення додаткової гнучкості. Зона – це група з одного чи кількох інтерфейсів, які мають схожі функції або особливості. Зони допомагають визначати, де слід застосовувати правило чи політику брандмауера Cisco IOS. На рисунку політики безпеки для LAN 1 і LAN 2 подібні, і їх можна згрупувати в зону для конфігурації брандмауера. За замовчуванням трафік між інтерфейсами в одній зоні не підпадає під жодну політику і проходить вільно. Проте весь трафік від зони до зони заблоковано. Щоб дозволити трафік між зонами, потрібно налаштувати політику, яка дозволить або перевірятиме трафік.

Єдиним винятком із такої політики **повної заборони** за замовчуванням є власна зона маршрутизатора.

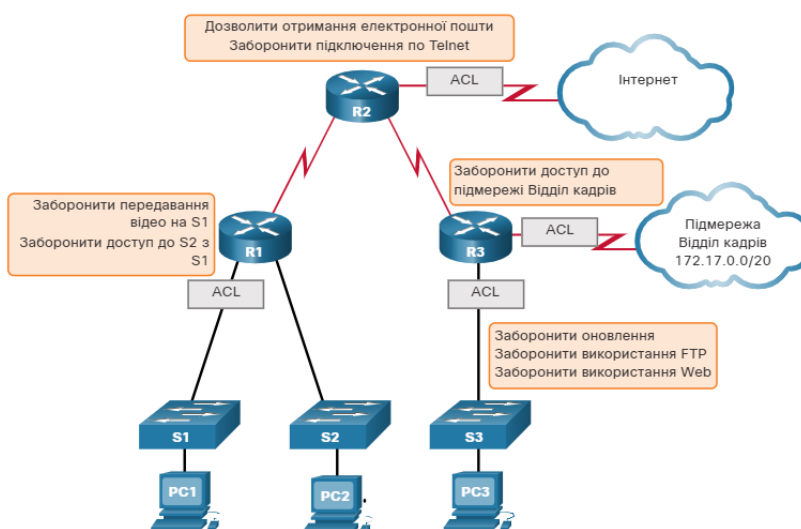
Переваги і недоліки IDS та IPS

Рішення	Переваги	Недоліки
IDS	- Немає впливу на мережу (затримка, коливання затримки (джитера)) - Немає впливу на мережу, якщо є збій сенсора - Немає впливу на мережу, якщо є перевантаження сенсора	- Дія у відповідь не може зупинити пакети-тригери - Потрібне правильне налаштування для дій у відповідь - Більш вразлива до методів обходу засобів мережної безпеки
IPS	- Зупиняє пакети-тригери - Може використовувати методи нормалізації потоку	- Проблеми з сенсором можуть вплинути на мережний трафік - Перевантаження сенсора впливає на мережу - Певний вплив на мережу (затримка, коливання затримки (джитера))

Що таке ACL?

Список контролю доступу (ACL) – це набір команд, які контролюють, чи пересилає пристрій пакети, чи скидає їх на основі інформації, знайденої в заголовку пакета. Налаштовані ACL виконують такі завдання:

- Обмежують мережний трафік, щоб підвищити продуктивність мережі.
- ACL можуть обмежувати доставку оновлень маршрутизації, щоб забезпечити надходження оновлень лише від відомих відправників.
- ACL можуть дозволити одному вузлу доступ до частини мережі та заборонити іншому вузлу доступ до тієї ж області.
- Фільтрують трафік залежно від типу. Наприклад, ACL може дозволити трафік електронної пошти, але заблокувати весь трафік Telnet.
- Перевіряють вузли, щоб дозволити чи заборонити доступ до мережних служб. ACL можуть дозволяти або блокувати доступ користувачеві до певних типів файлів, зокрема, FTP або HTTP.



SNMP

Простий протокол керування мережею (SNMP, Simple Network Management Protocol) дозволяє адміністраторам керувати кінцевими пристроями в IP-мережі, зокрема серверами, робочими станціями, маршрутизаторами, комутаторами та пристроями безпеки. Він діє змогу мережним адміністраторам контролювати та керувати продуктивністю мережі, знаходити й вирішувати проблеми в роботі мережі та планувати її зростання.

Сервери AAA

Аутентифікація (Authentication)

- Користувачі й адміністратори повинні довести, що вони саме ті, за кого себе видають.
- Аутентифікація AAA забезпечує централізований спосіб контролю доступу до мережі.

Авторизація (Authorization)

- Після аутентифікації користувача, служба авторизації визначає, до яких ресурсів і операцій цей користувач може мати доступ.
- Наприклад, «Користувач 'student' може отримати доступ до хост-сервера XYZ лише за допомогою SSH.»

Облік (Accounting)

- Процедура обліку передбачає фіксацію дій користувача, зокрема, до чого він мав доступ, як довго використовував ресурс, які зміни вносив.
- Служба обліку відстежує використання мережних ресурсів.
- Наприклад, «Користувач 'student' мав доступ до хост-сервера XYZ за допомогою SSH протягом 15 хвилин.»

Terminal Access Controller Access-Control System Plus (TACACS+) та Remote Authentication Dial-In User Service (RADIUS) – це протоколи автентифікації, які використовуються для взаємодії з AAA-серверами.

	TACACS+	RADIUS
Функціональність	Розділяє AAA відповідно до архітектури AAA, що забезпечує модульність реалізації сервера безпеки	Поєднує автентифікацію та авторизацію, але відокремлює облік, що забезпечує меншу гнучкість у реалізації, ніж TACACS+
Стандарт	В основному підтримується Cisco	Стандарт Open/RFC
Транспортний протокол	TCP	UDP
Протокол CHAP	Двонаправлений виклик і відповідь, що використовуються в протоколі автентифікації виклику рукописання (CHAP)	Односпрямований виклик і відповідь від сервера безпеки RADIUS клієнту RADIUS
Конфіденційність	Весь пакет зашифрований	Пароль зашифрований
Кастомізація	Забезпечує авторизацію команд маршрутизатора для кожного користувача чи групи	Не має можливості авторизувати команди маршрутизатора для кожного користувача чи групи
Облік	Обмежений	Розширений